LABORATUVAR 2 · ARMA MANTAR BARİYER · KİMYA TESİSİ GİRİŞİ

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad Mehmet Onur Boyraz · 245541023 | Grup | Tarih 19.10.2026

> **Kavram: Zone**, aynı kritiklikteki ve birbirine güvenen varlıkların bölgesidir. **Conduit**, bölgeler arasındaki her iletişim yoludur; her biri kontrollü bir kapıdır. Her bölgeye bir hedef güvenlik seviyesi (**SL-T 1–4**) veriyoruz; bölgedeki en kritik varlık seviyeyi belirler. 62443'ün maddelerini ezberlemiyoruz, mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi

16 varlık + 5 dış bağlantı · ! = senaryoya eklenen zayıflık V

SAHA VE KONTROL

1. Mantar bariyer ×3 + uç konum sensörleri G
2. Hidrolik ünite panosu (pompa motoru + valfler) G
3. Arma Kart [EE51KAR] G — HTTP/80, varsayılan parola !
4. Safety PLC / emniyet rölesi (LAB 1 hedefi) V
5. Loop dedektör G
6. Fotosel G — yanlış alarm yüzünden bypass'ta !
7. Acil stop butonları (kulübe + saha) V
8. Trafik lambası + LED flaşör G
9. RF kumanda alıcısı — 433 MHz sabit kod !

GEÇİŞ, KULÜBE VE İLETİŞİM

10. Plaka tanıma IP kamerası G — varsayılan web parolası !
11. Kart okuyucu + geçiş kontrol kontrolcüsü G
12. ARM.v19™ YZ kutusu (edge) G
13. Kulübe PC: Arma WOC G — TeamViewer, 2 kilitsiz USB !
14. 4G router — varsayılan parola, port yönlendirme !
15. Kulübe Wi-Fi AP — parolası duvarda yazılı !
16. NVR (CCTV kayıt cihazı) V

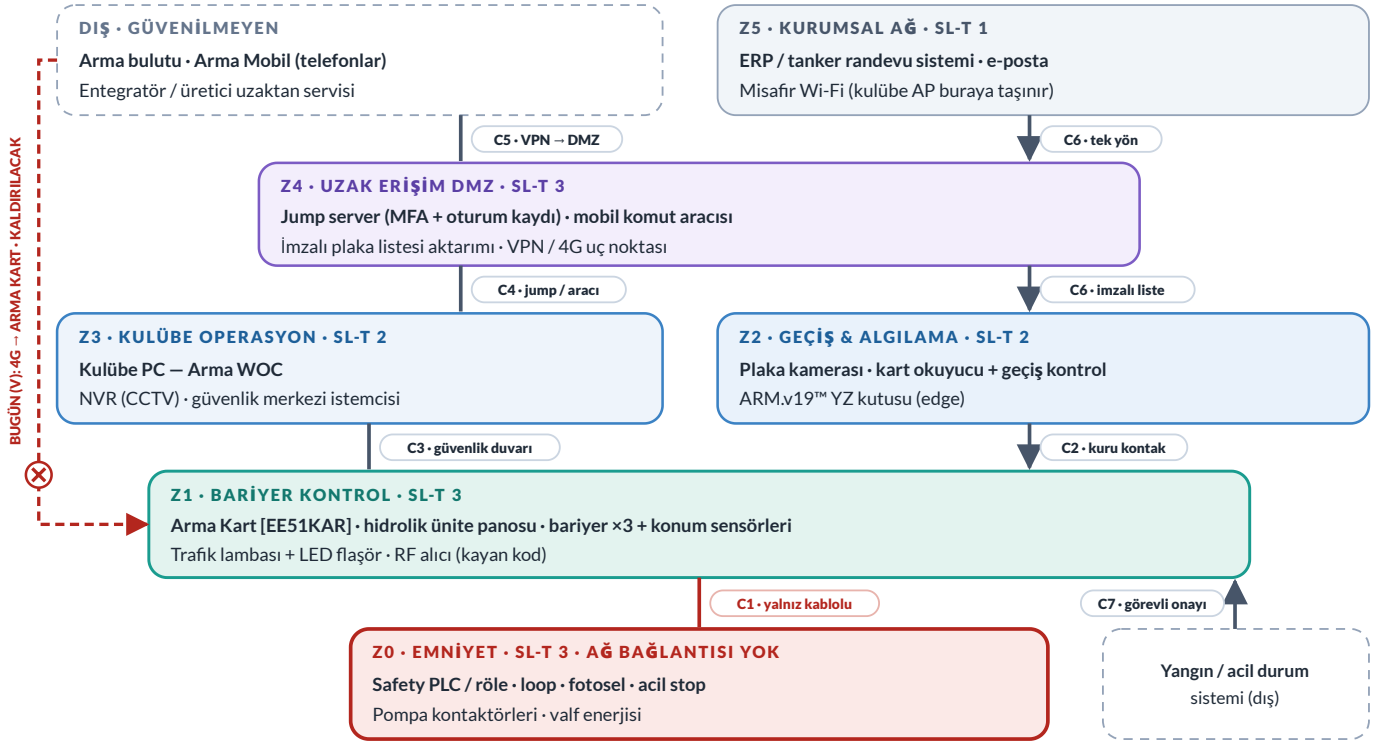
DIŞ BAĞLANTILAR **D1** Arma bulutu / Arma Mobil G — tek paylaşılan hesap ! · **D2** Entegratör uzaktan servisi (TeamViewer) · **D3** ERP / tanker randevu → plaka listesi · **D4** Tesis güvenlik merkezi (VMS + geçiş kontrol) · **D5** Yangın / acil durum sistemi

1 **Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.**

> Altı bölge kurduk. Safety PLC tek başına **Z0**'da, hiçbir ağa bağlı değil; LAB 1'deki "SF-1 ağdan yapılandırılamaz" gereksiniminin bölge karşılığı. Şema 2. sayfada.

Bölge	Varlıklar	SL-T	Neden bu grup?
Z0 · Emniyet	4 Safety PLC · 5 loop · 6 fotosel · 7 acil stop · pompa kontaktörleri	**3 · ağ yok**	İnsanı koruyan SF-1/SF-2 burada; hiçbir ağdan ulaşılamamalı
Z1 · Bariyer kontrol	1 bariyerler · 2 hidrolik pano · 3 Arma Kart · 8 trafik lambası · 9 RF alıcı	**3**	Kapıyı fiziksel olarak açan aktüatör; ele geçirilirse hem çevre güvenliği hem insan etkilenir
Z2 · Geçiş & algılama	10 plaka kamerası · 11 kart okuyucu/geçiş kontrol · 12 YZ kutusu	**2**	"Kim geçebilir" kararını üretir; Z1'e yalnız olay gönderir, komut almaz
Z3 · Kulübe operasyon	13 kulübe PC (WOC) · 16 NVR · D4 güvenlik merkezi istemcisi	**2**	İnsanın kullandığı Windows istasyonu: geniş saldırı yüzeyi ama doğrudan aktüatör değil
Z4 · Uzak erişim DMZ	Jump server · mobil komut aracısı · imzalı liste aktarımı · 14 4G/VPN ucu (buraya taşınır)	**3**	Dışarıdan gelen her bağlantı burada sonlanır; içerisi dışarıyı doğrudan görmez
Z5 · Kurumsal	D3 ERP/tanker randevu · e-posta · 15 Wi-Fi (misafir ağı olarak taşınır)	**1**	Endüstriyel sistemin dışında; yalnız tek yönlü veri verir
Dış	D1 Arma bulutu/Mobil · D2 entegratör · D5 yangın sistemi	**—**	Kontrolümüz dışında; yalnız C5 ve C7 kapılarından girebilir

Çıktı — Zone / Conduit Diagram (hedef mimari)



— conduit = kontrollü kapı · ↓ tek yönlü akış · ✕ **kırmızı kesikli** = bugün var olan kontrolsüz yol V; hedef mimaride yok. C8 (USB/servis dizüstü) fiziksel bir conduit olduğu için şemada değil, tabloda.

2 Arma Mobil'in "her yerden kontrol" yolu bugün hangi bölgeye düşüyor — ve orada KALABİLİR Mİ? Neden?

Bugün V: telefon → Arma bulutu → saha panosundaki 4G router → port yönlendirme → Arma Kart. İnternet hiçbir kapıdan geçmeden doğrudan **Z1**'de sonlanıyor. LAB 1 varsayımına göre emniyet mantığı da aynı kartta olduğu için pratikte **Z0'a kadar** iniyor (şemadaki kırmızı ✕ yol).

KALAMAZ. (1) SL-T 3 bir bölgeye güvenilmeyen ağdan kontrolsüz bir conduit açıyor; bu, "her geçiş bir kapıdan" mantığına aykırı. (2) Tek paylaşılan hesap ve varsayılan router parolası yüzünden kimlik doğrulama (FR1) ve kullanım kontrolü (FR2) fiilen yok. (3) "Aç" komutu bariyeri indirir; kimin verdiği kayıt altında değil (FR6).

Hedef: 4G/VPN ucu Z4'e taşınır; internetten içeri port açılmaz, Arma bulutuna yalnız giden bağlantı kurulur. Mobil "aç" isteği Z4'teki komut aracısına düşer; Z3'teki görevli WOC'ta onaylarsa Z1'e iletilir. Mobil yoldan yapılandırma ya da firmware değiştirilemez. Z0'a hiçbir ağ yolu yoktur.

! Zayıflık V (varlık no.)	Bölge / conduit kararı
Arma Kart HTTP/80 + varsayılan parola (3)	Z1'de kalır; arayüze yalnız C3 üzerinden WOC erişir; parola değişir; yapılandırma yalnız panodaki anahtarlı bakım modunda
Fotosel bypass'ta (6)	Z0; bypass yalnız fiziksel anahtarla ve süreli; yazılımdan kapatılamaz
RF 433 MHz sabit kod (9)	Z1; kayan kodlu alıcıyla değişir, yalnız "aç talebi" taşır
Plaka kamerası varsayılan parola (10)	Z2; parola değişir; Z1'e yalnız C2 üzerinden tek yönlü olay
TeamViewer 7/24 + 2 kilitsiz USB (13)	Z3; TeamViewer kaldırılır, yerine C4 jump server; USB'ler kilitlenir (C8)
4G router varsayılan parola + port yönlendirme (14)	Z1'den Z4'e taşınır; C5 yalnız VPN ve giden bağlantı
Wi-Fi parolası duvarda (15)	Z3'ten çıkarılır, Z5 misafir ağına; Z1–Z3'e kablosuz conduit yok
Paylaşılan Arma Mobil hesabı (D1)	Dış → Z4; kişisel hesap + MFA (Görev B)

SL-T seviyeleri neden böyle? SL-T 3: IACS'e özgü bilgisi olan, orta kaynaklı kasıtlı saldırgana karşı koruma; BEKRA kapsamındaki bir tesis kapısı ve onu açan aktüatör için makul. **SL-T 2:** basit araçlarla kasıtlı saldırıya karşı. **SL-T 1:** rastlantısal hatalara karşı.

3 **Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?**

> Sekiz conduit var; her birinde neyin geçmesine izin verildiği ve nasıl denetlendiği aşağıda. Parantezdeki FR'ler 62443'ün temel gereksinimleri: FR1 kimlik doğrulama · FR2 kullanım kontrolü · FR3 bütünlük · FR5 kısıtlı veri akışı · FR6 olay kaydı ve yanıt.

Conduit	Geçiş	İzin verilen akış	Kontrol
C1	Z1 ↔ Z0	Yalnız iki kablolu sinyal: "yükselme talebi" (Z1→Z0), "izin / arıza durumu" (Z0→Z1)	Ağ protokolü yok; mühürlü pano; periyodik fonksiyon testi FR3 · FR5
C2	Z2 → Z1	"Yetkili araç" olayı (kuru kontak / RS-485)	Tek yön; olay loop doluluğuyla eşleşmezse yok sayılır; araç başına tek olay FR3 · FR5
C3	Z3 ↔ Z1	WOC ↔ Arma Kart: yalnız aç / kapat / durum	Endüstriyel güvenlik duvarı: yalnız kulübe PC'sinin IP'si ve WOC portu; yapılandırma yazma kapalı; tüm komutlar loglanır FR2 · FR5 · FR6
C4	Z4 ↔ Z3	Jump server oturumu; mobil "aç" isteği → görevli onayı	MFA, kişisel hesap, oturum kaydı, süre sınırı; görevli onaylamadan mobil istek Z3'e geçmez FR1 · FR2 · FR6
C5	Dış ↔ Z4	Servis için VPN; Arma bulutuna giden bağlantı	İçeri port yok; VPN + MFA; bağlantı yalnız Z4'te sonlanır FR1 · FR5
C6	Z5 → Z4 → Z2	Günlük plaka / randevu listesi	Tek yönlü aktarım (veri diyodu ya da yalnız dışarı itme); imzalı liste; ters yönde akış yok FR3 · FR5
C7	D5 → Z1	"Acil indirme talebi" (kablolu kontak)	Görevli onayı ya da yalnız iç bariyer hattına uygulanır; her tetik loglanır — sahte yangın alarmıyla kapı açtırmaya karşı FR2 · FR6
C8	USB / servis dizüstü → Z3, Z1	Firmware ve parametre yükleme	USB'ler kilitli; dizüstü önce tarama istasyonundan geçer; yalnız imzalı firmware; yerinde ve iki kişiyle FR2 · FR3

Görev B — uzak erişim kararı (6 satır + 1)

Karar	Seçenekler	Seçimimiz + nedeni
Aracı?	Doğrudan / Jump server	**Jump server (Z4).** Hiçbir dış oturum Z1 ya da Z3'e doğrudan değmemeli; tek kontrol noktası olur. Bugün: TeamViewer doğrudan kulübe PC'sine, 4G doğrudan Arma Kart'a.
Tünel?	Açık / VPN	**VPN, yalnız Z4'e.** 4G router'daki port yönlendirme kaldırılır; Arma bulutu bağlantısı yalnız giden yönde. Bugün: açık port.
Kimlik?	Parola / MFA	**MFA** — hem entegratör hem Arma Mobil kullanıcıları için. Ele geçirilmiş bir parola, kapıyı açan bir el demek. Bugün: yalnız parola.
Hesap?	Paylaşılan / Kişisel	**Kişisel.** Her teknisyen ve her vardiya amiri kendi hesabını kullanır; "bariyeri kim açtı?" sorusunun cevabı kalmalı (LAB 6'nın kanıtı). Bugün: tek paylaşılan hesap.
Kayıt?	Yok / Tam oturum kaydı	**Tam oturum kaydı.** Servis oturumunun videosu + komut logları; mobil komutlar kullanıcı, zaman ve konumla; loglar güvenlik merkezine. Bugün: kayıt yok.
Zamanlama?	Sürekli açık / Varsayılan kapalı	**Varsayılan kapalı.** Servis erişimi talep + vardiya amiri onayı + 2 saatlik pencere; süre bitince otomatik kapanır. Bugün: 7/24 açık.
+1 Yetki kapsamı? makineye özel	Tam yetki / Komut kısıtlı	**Komut kısıtlı.** Uzaktan yalnız "aç talebi" ve rapor; parametre ve firmware değişikliği yalnız yerinde, anahtarlı bakım modunda. SF-1 ayarlarına (loop hassasiyeti, fotosel, gecikme) uzaktan erişim yok.

G üreticinin sitesinde yazan bilgi · V eğitim senaryosu varsayımı, **Arma ürünü hakkında iddia değildir** · **!** senaryoya eklenen zayıflık. Kaynaklar: armakontrol.com (ürün, C-serisi/Arma WOC, Arma Mobil, Yapay Zeka sayfaları) · IEC 62443-3-2 (bölge/conduit, SL-T) · IEC 62443-3-3 (FR1–FR7).

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.